CMP-X305 Cyber Security Coursework Portfolio 1

Student name: [Add your name here]

Student ID: [Add your student ID here]

Module: Cyber Security (CMP-X305)

Submission date: 31 March 2026

1. Introduction

This portfolio documents four practical cyber security labs completed during Weeks 05, 07, 08 and 09. The work covers WordPress assessment with WPScan, exploitation of web application weaknesses in OWASP Juice Shop, network discovery and secure administration with Nmap and SSH, and vulnerability scanning with Nessus.

The evidence used in this report comes from my own screenshots, the exported Nessus PDF reports, and the module worksheets provided for each lab. Representative screenshots are embedded throughout the report, while the full evidence pack remains in the week folders stored alongside this file.

This portfolio addresses the module learning outcomes in the following ways:

- **LO1:** identifying vulnerabilities and recommending mitigations
- **LO2:** applying secure remote access and discussing confidentiality, integrity and availability
- **LO3:** evaluating privacy and anonymity risks caused by information leakage and insecure web behaviour

2. Week 05 - Web Application Security Lab (WPScan)

2.1 Aim

The purpose of this lab was to assess a WordPress installation using WPScan and demonstrate how a scanner can reveal themes, plugins, configuration weaknesses and authentication attack surface. This directly relates to privacy and anonymity because version disclosure and exposed directories make targeted attacks easier.

2.2 Method

I first verified that the WordPress site and admin area were reachable from Kali Linux. I then prepared the target by managing themes and testing the login and registration pages so that WPScan had a realistic target to assess. After that, I updated WPScan and used it to enumerate installed themes, plugins, configuration backups and password attack options against XML-RPC.

2.3 Evidence

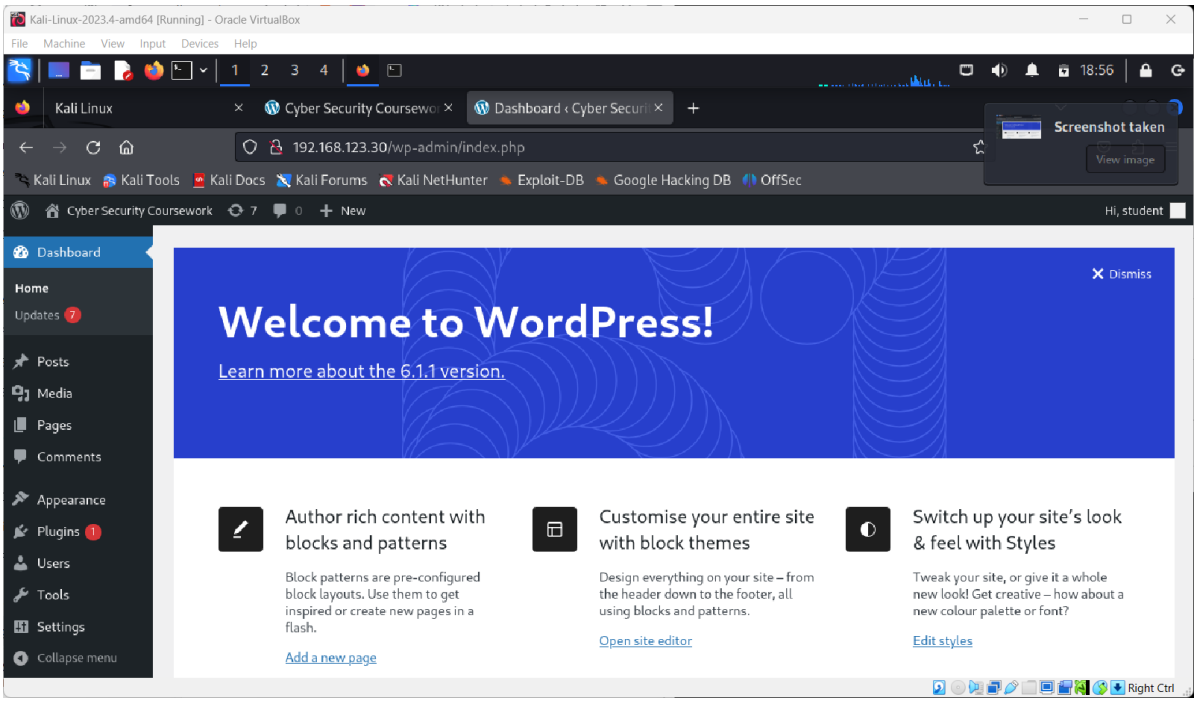

Figure 1. The WordPress admin dashboard was reachable from the lab environment, confirming the target was operational.

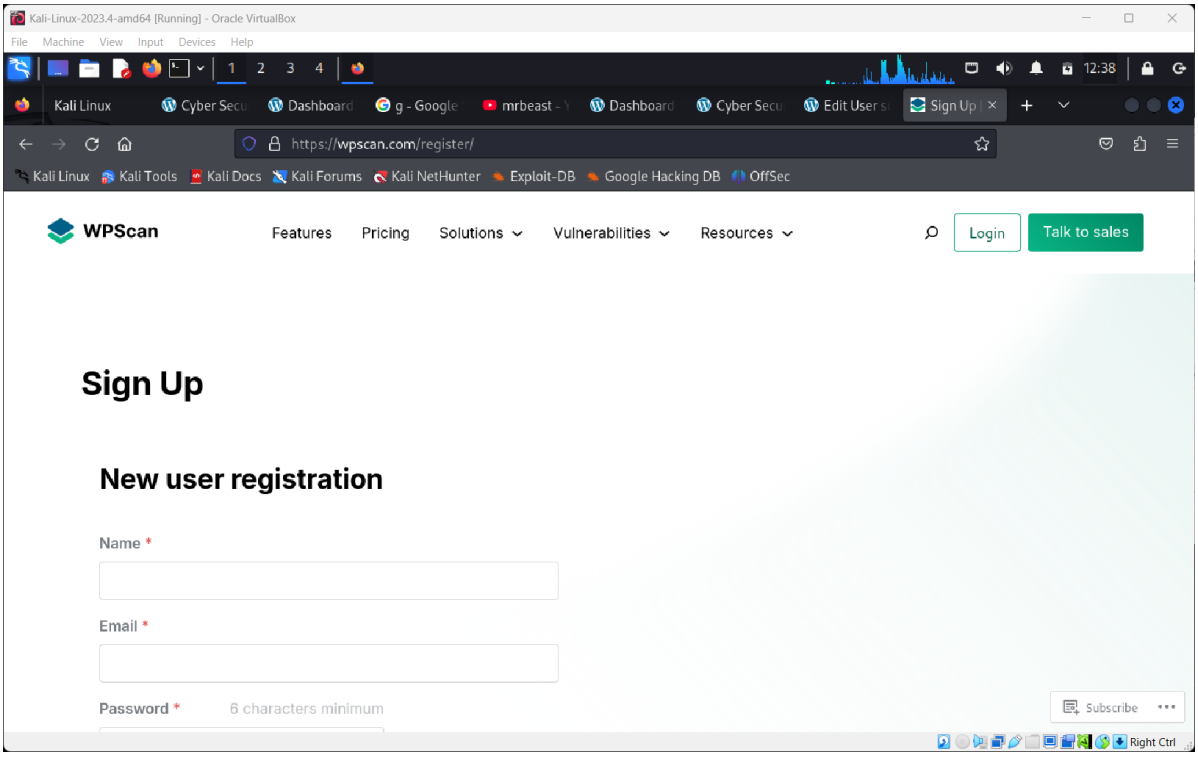

Figure 2. User registration and authentication testing before scanning.

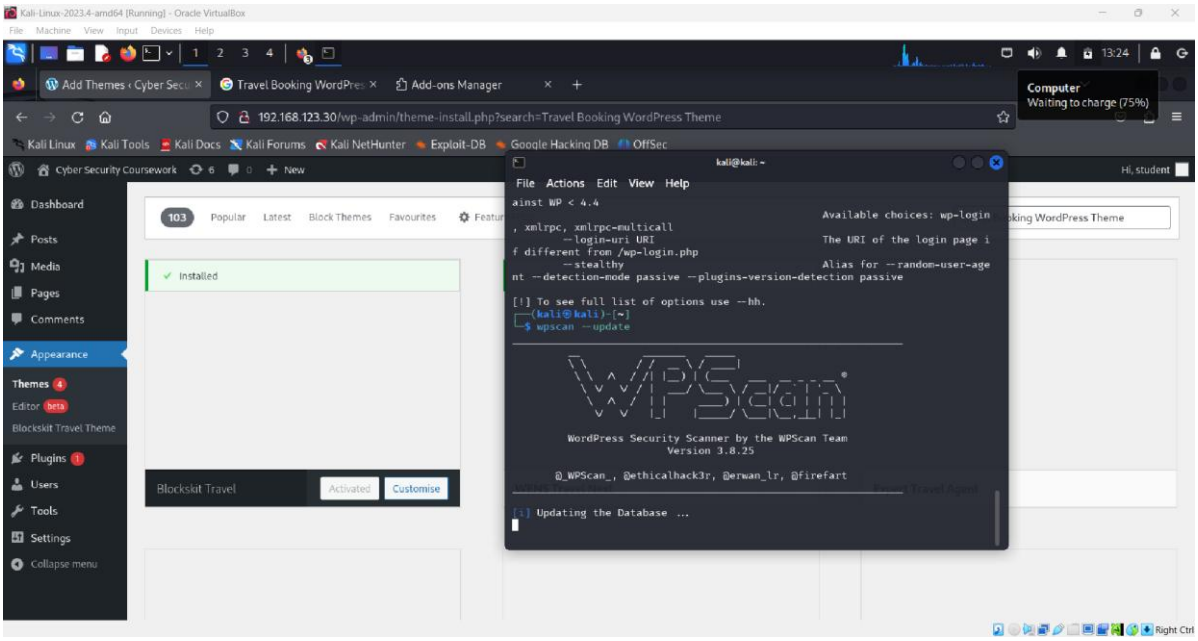

Figure 3. Theme configuration in WordPress together with WPScan setup in Kali.

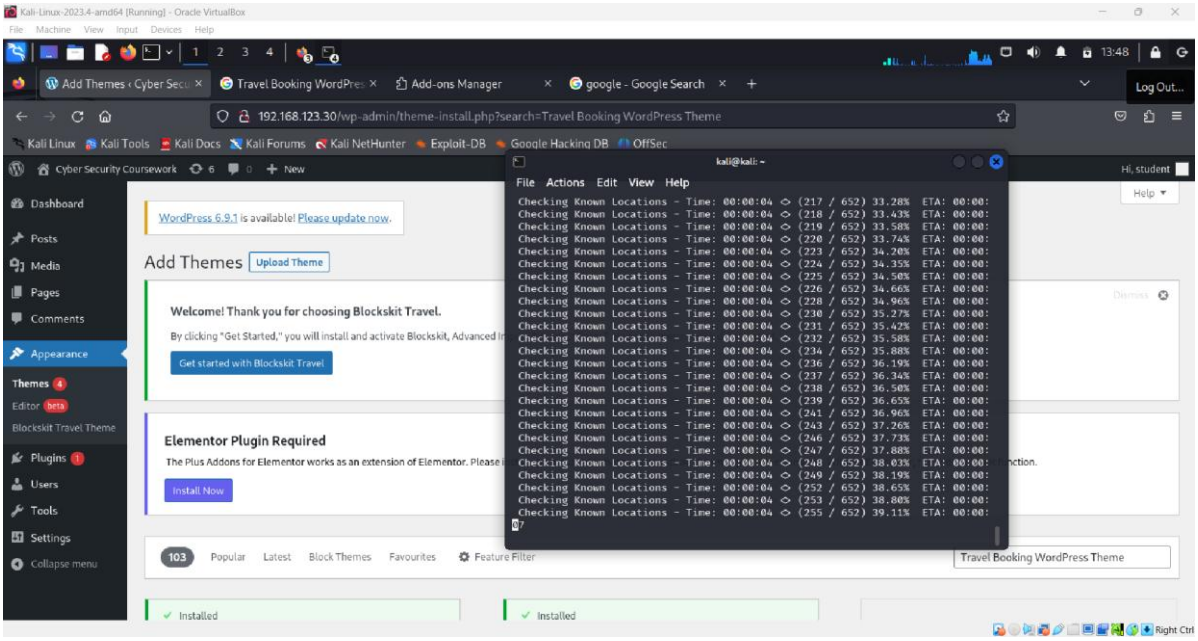

Figure 4. WPScan performing location and asset enumeration against the WordPress target.

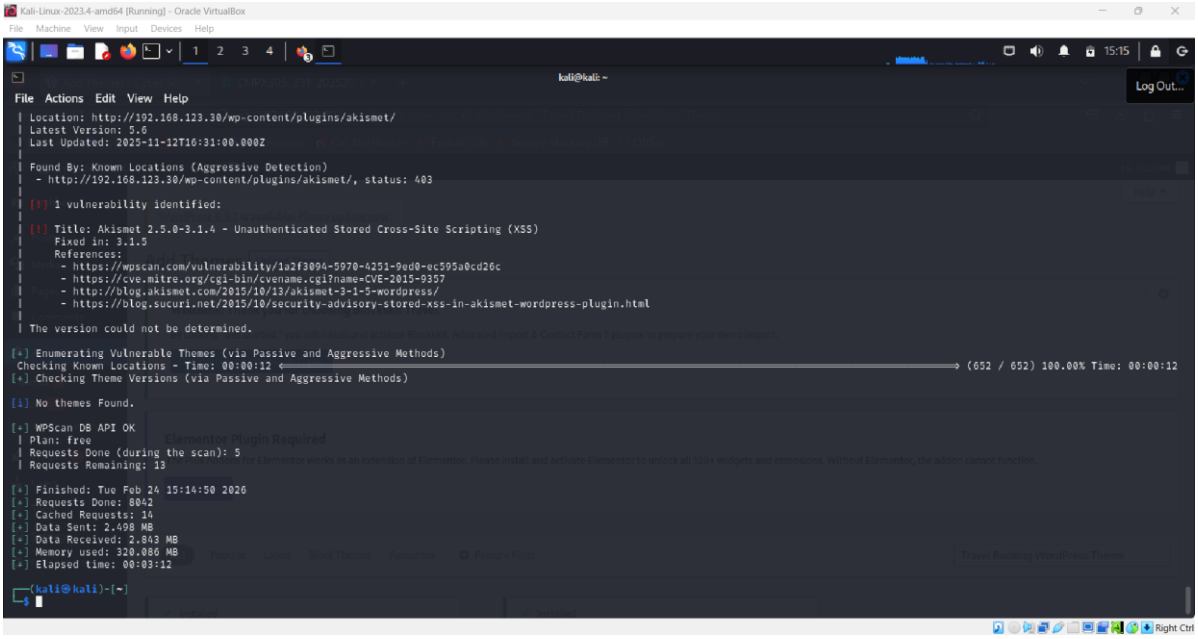

Figure 5. WPScan located the Akismet plugin path and referenced a historical stored XSS advisory.

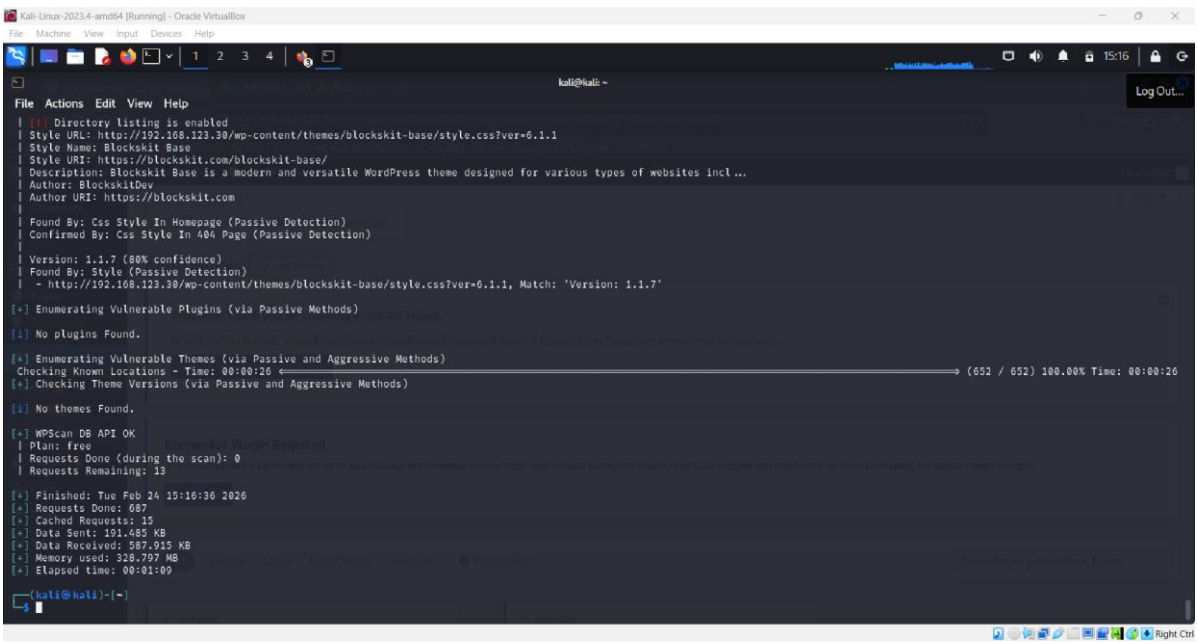

Figure 6. WPScan reported directory listing on the theme path and completed the scan.

2.4 Findings and analysis

Finding	Evidence	Security impact	Assessment
Theme metadata exposed	WPScan detected the Blockskit Base theme and version 1.1.7 .	Version disclosure makes it easier to match the site to known vulnerabilities.	This is reconnaissance rather than compromise, but it reduces attacker uncertainty.
Directory listing enabled	WPScan reported directory listing on the theme path.	File names and structure can be browsed and used to support later attacks.	This should be remediated by disabling directory indexes.

Potential vulnerable plugin history	WPScan referenced Akismet 2.5.0-3.1.4 - Unauthenticated Stored Cross-Site Scripting (XSS) but did not confirm the installed version.	If the vulnerable version were present, stored XSS could affect integrity and trust.	This should be treated as a lead for manual validation, not an automatically confirmed exploit.
Patch lag visible	The WordPress UI showed that version 6.9.1 was available.	Delayed updates increase exposure to known weaknesses.	Regular patching is a basic hardening requirement.
XML-RPC password attack unsuccessful	WPScan attempted a password attack against XML-RPC but returned no valid passwords.	The test did not compromise the account in the captured run.	Even so, XML-RPC remains an attractive attack surface and should be restricted if not needed.

The strongest confirmed weakness in the captured evidence was the directory listing exposure, because it clearly leaked information without any real business need. The Akismet result was useful, but it also showed an important limitation of automated scanning: tools often identify promising leads that still require human judgment before they can be reported as confirmed vulnerabilities.

2.5 Reflection

This lab showed that web application assessment is not only about running a scanner but also about interpreting its output critically. WPScan was effective at gathering reconnaissance data quickly, but understanding whether a result was a genuine vulnerability or just an indicator was equally important. If I were hardening this system, I would disable directory indexing, remove unused themes and plugins, patch WordPress promptly, enforce stronger passwords and restrict XML-RPC.

3. Week 07 - OWASP Juice Shop Lab

3.1 Aim

The Juice Shop lab focused on exploiting deliberately vulnerable web application behaviour. Instead of passive scanning, this lab required direct interaction with the application in order to complete multiple challenges and understand how poor input validation, weak authentication and insecure business logic can be abused.

3.2 Completed challenges

The screenshots show eight solved one-star challenges:

Challenge	**Difficulty**	**Technique / weakness demonstrated**	**Security lesson**
Login Admin	1 star	Authentication abuse and access to the administrator account	Administrative accounts require strong protection and monitoring.
Bully Chatbot	1 star	Abusing chatbot logic to obtain a coupon	Business logic flaws can be as serious as coding bugs.
Outdated Allowlist	1 star	Redirecting to an outdated	Stale allowlists create

		trusted cryptocurrency address	integrity risk.
Bonus Payload	1 star	DOM XSS using a richer iframe payload in the search feature	Unsanitised input can result in active content execution.
DOM XSS	1 star	Injecting <iframe src="javascript:alert('xss')"> into search	Client-side input handling can undermine integrity and confidentiality.
Privacy Policy	1 star	Discovering and visiting a public policy page	Small information disclosures support reconnaissance.
Mass Dispel	1 star	Closing multiple challenge banners in one action	Weak state management creates unexpected behaviour.
Error Handling	1 star	Triggering an error that was not handled cleanly	Poor exception handling helps attackers understand an application.

3.3 Evidence

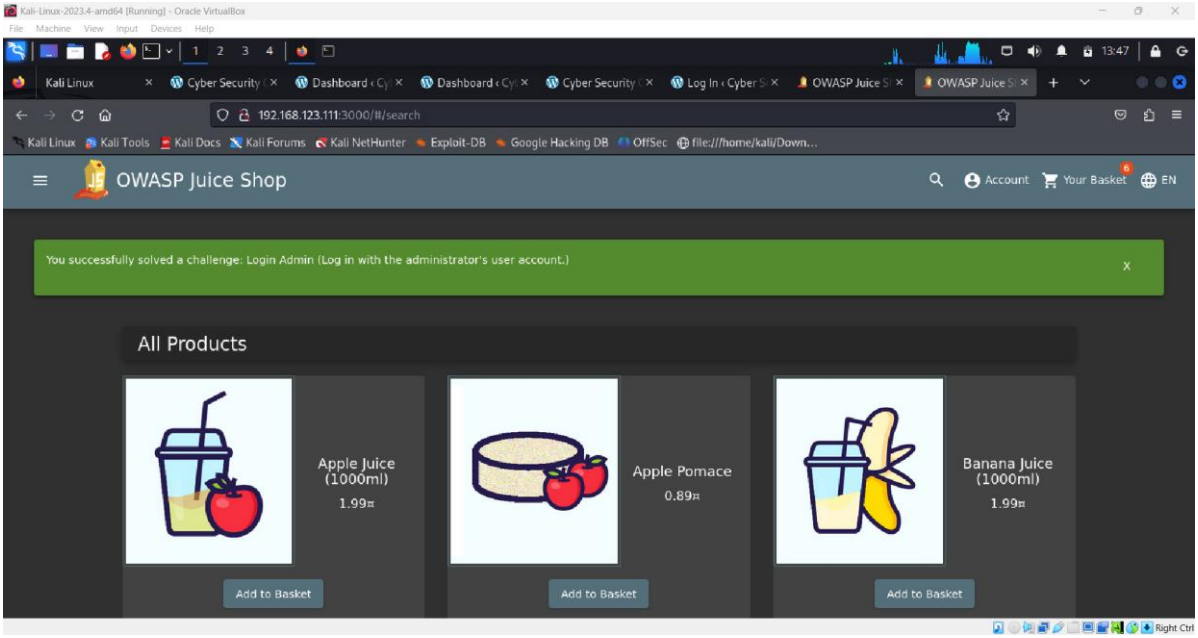

Figure 7. Login Admin completed successfully.

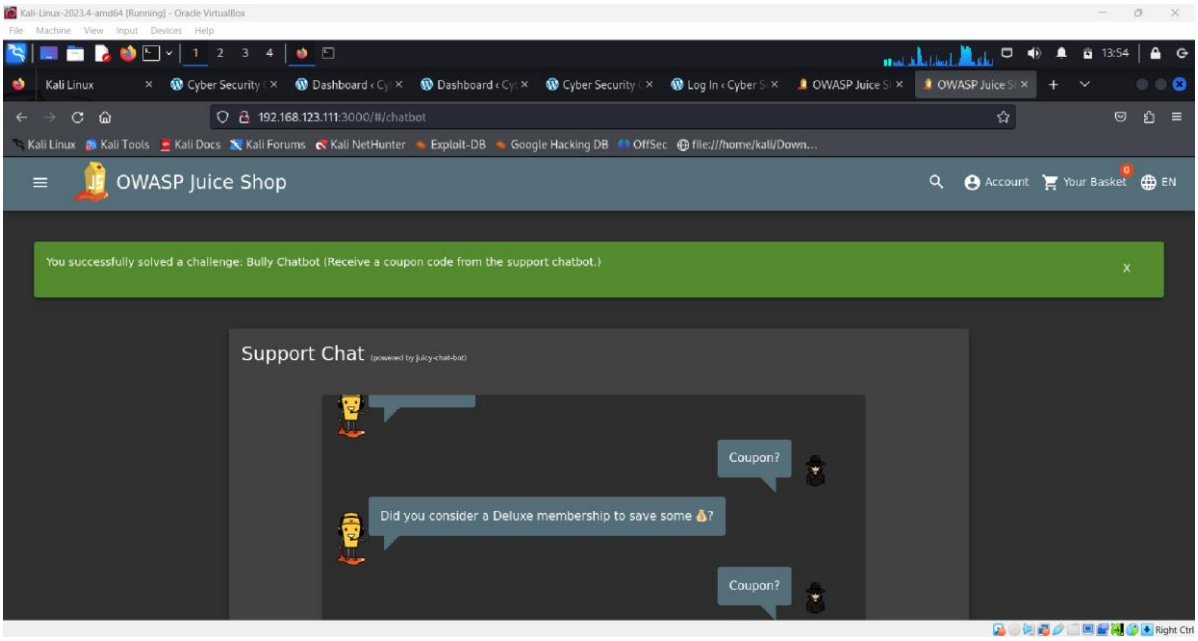

Figure 8. Bully Chatbot solved by manipulating the support bot into returning a coupon.

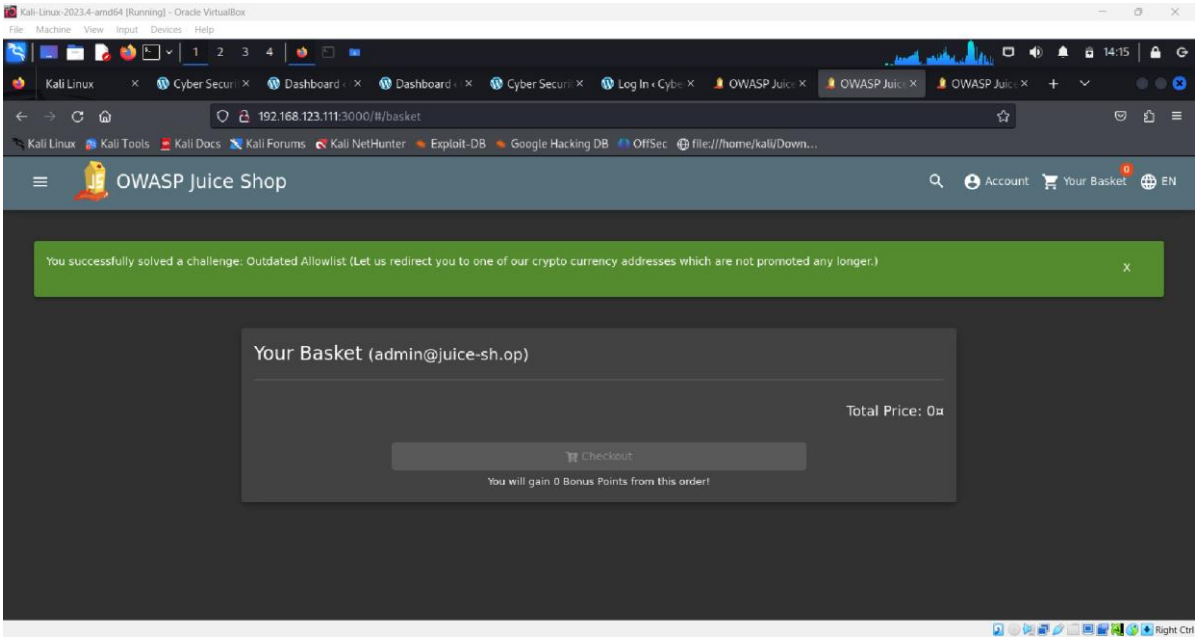

Figure 9. Outdated Allowlist solved by reaching a deprecated but trusted destination.

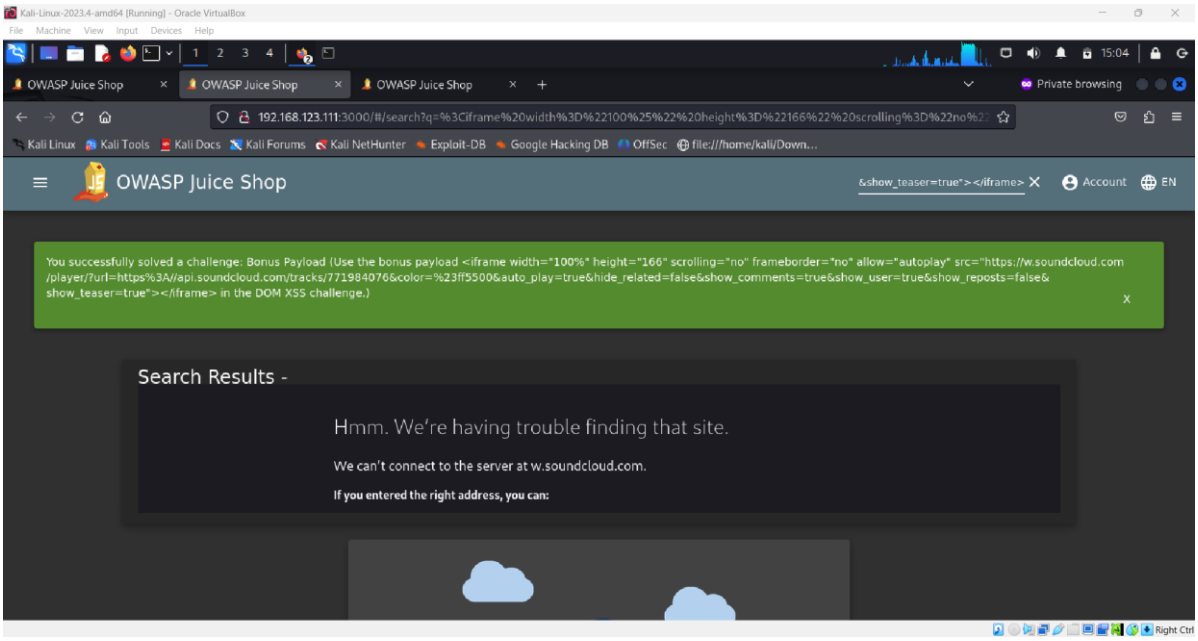

Figure 10. Bonus Payload solved using a more advanced DOM XSS search payload.

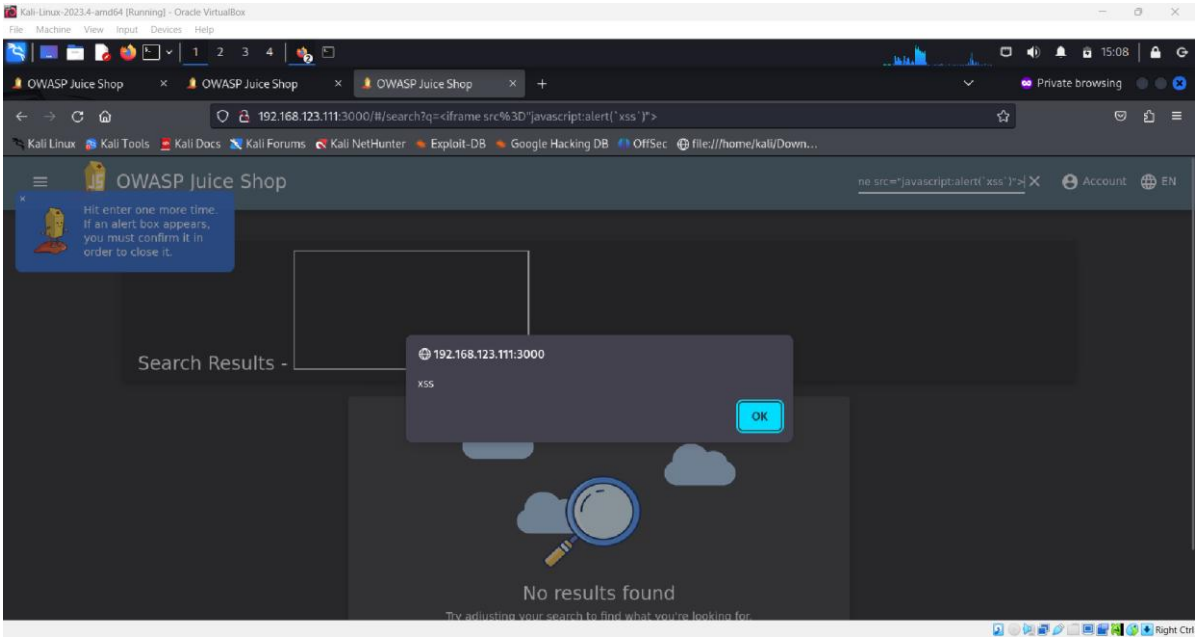

Figure 11. DOM XSS confirmed when the payload executed in the browser.

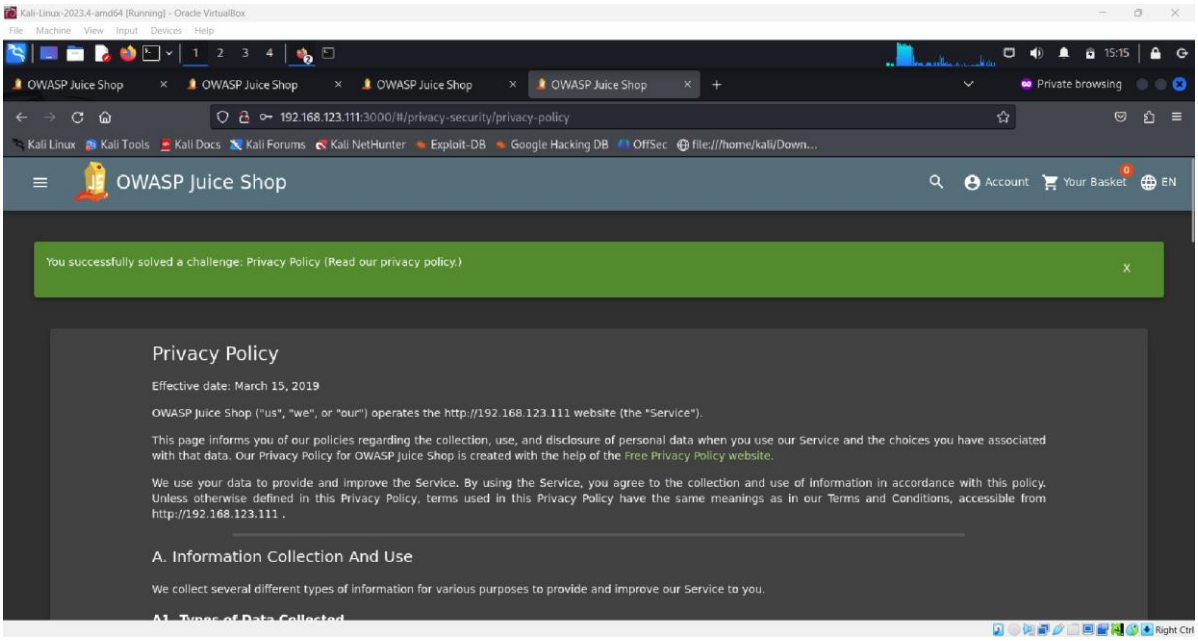

Figure 12. Privacy Policy challenge solved.

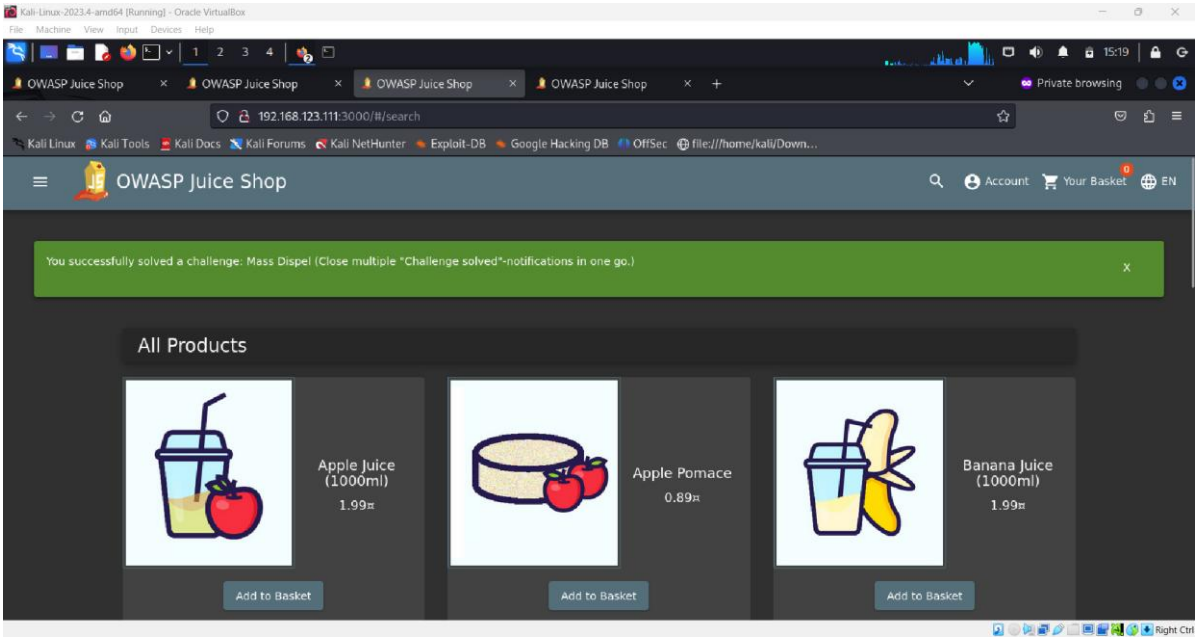

Figure 13. Mass Dispel solved by closing multiple notifications in one action.

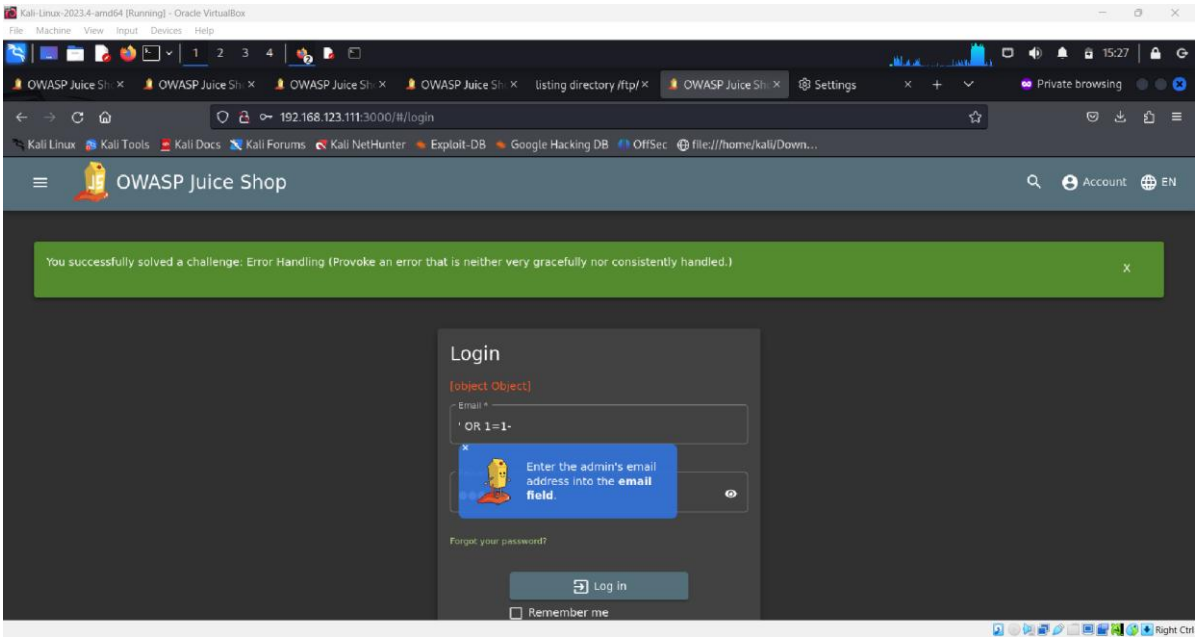

Figure 14. Error Handling solved after provoking an inconsistent application error.

3.4 Analysis

The most technically significant part of this lab was the XSS work. Both the standard DOM XSS challenge and the Bonus Payload challenge demonstrated that unsanitised client-side input can reach the DOM and execute attacker-controlled content. In a real application, that could lead to session theft, phishing or unauthorised actions performed in the victim's browser.

The other challenges showed that not all serious security problems come from classic code injection. Login Admin highlighted weak authentication controls, Bully Chatbot showed business logic abuse, and Error Handling demonstrated the value of clean defensive failure. Even apparently simple tasks such as visiting the privacy policy page reflected a real-world truth: attackers often start by collecting small pieces of information.

3.5 Reflection

This lab improved my understanding of how web vulnerabilities behave in practice. Instead of reading about XSS or authentication weaknesses in theory, I had to craft inputs, observe the application's responses and recognise successful exploitation. In a real system, the main mitigations would include secure authentication controls, strong input validation and output encoding, better business logic checks and safer error handling.

4. Week 08 - Vulnerability Assessment Lab (Nmap and SSH)

4.1 Aim

Week 08 combined reconnaissance and defence. Nmap was used to identify live hosts and exposed services, while SSH was used to demonstrate secure remote administration, key-based authentication, tunnelling and file transfer. This lab connected strongly to LO1 and LO2.

4.2 Nmap evidence and findings

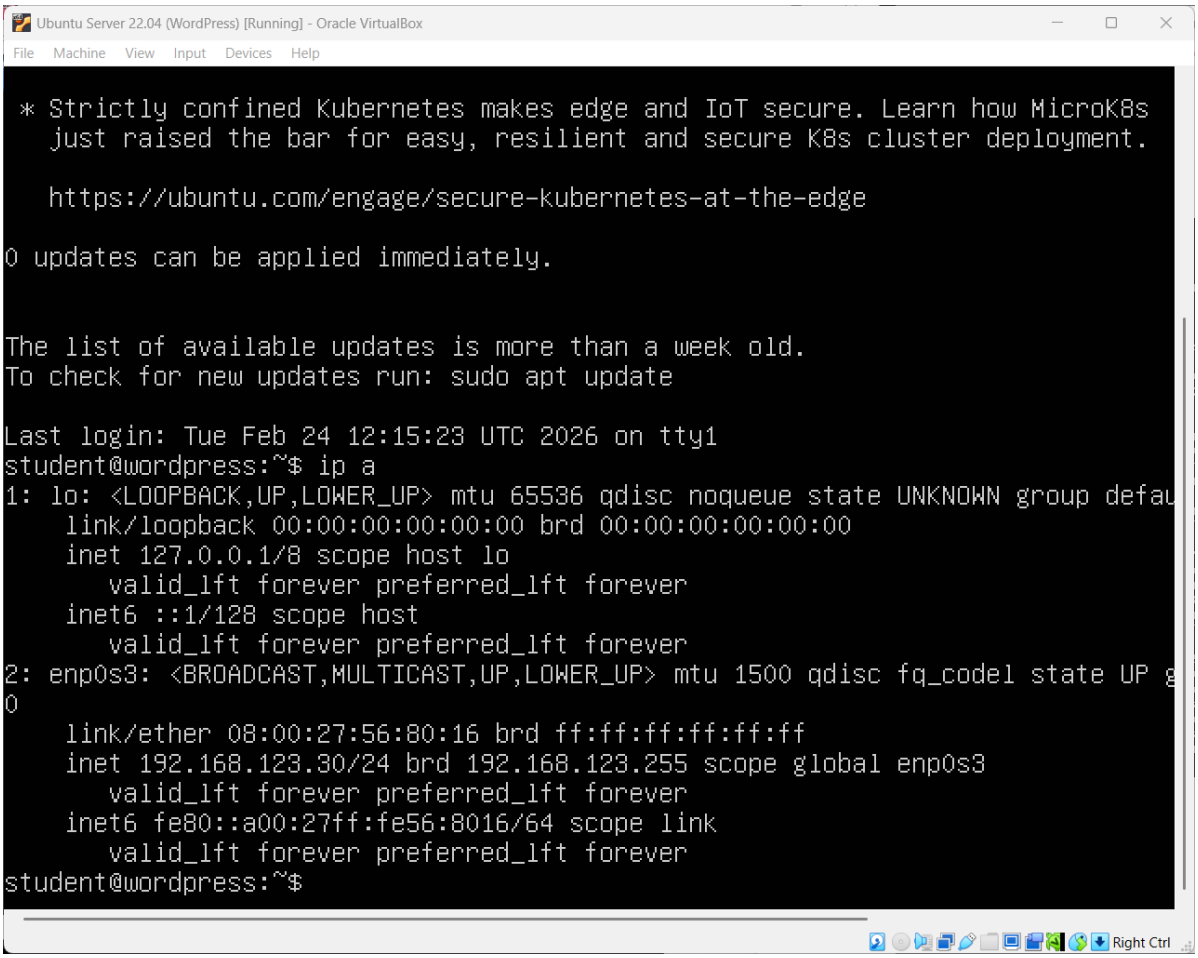

Figure 15. The WordPress host was identified at `192.168.123.30` before scanning.

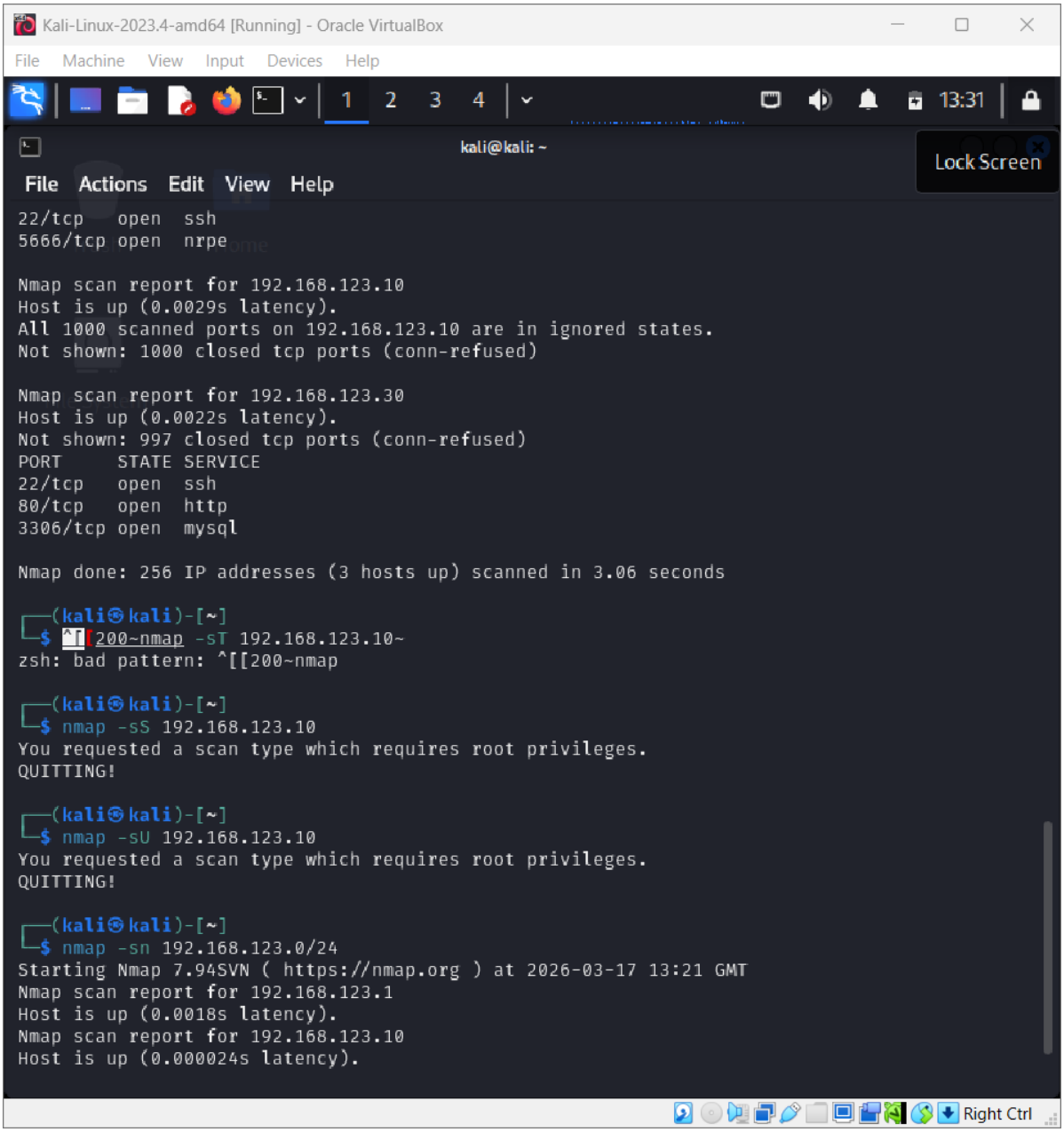

Figure 16. Nmap host discovery identified live hosts and the main exposed services.

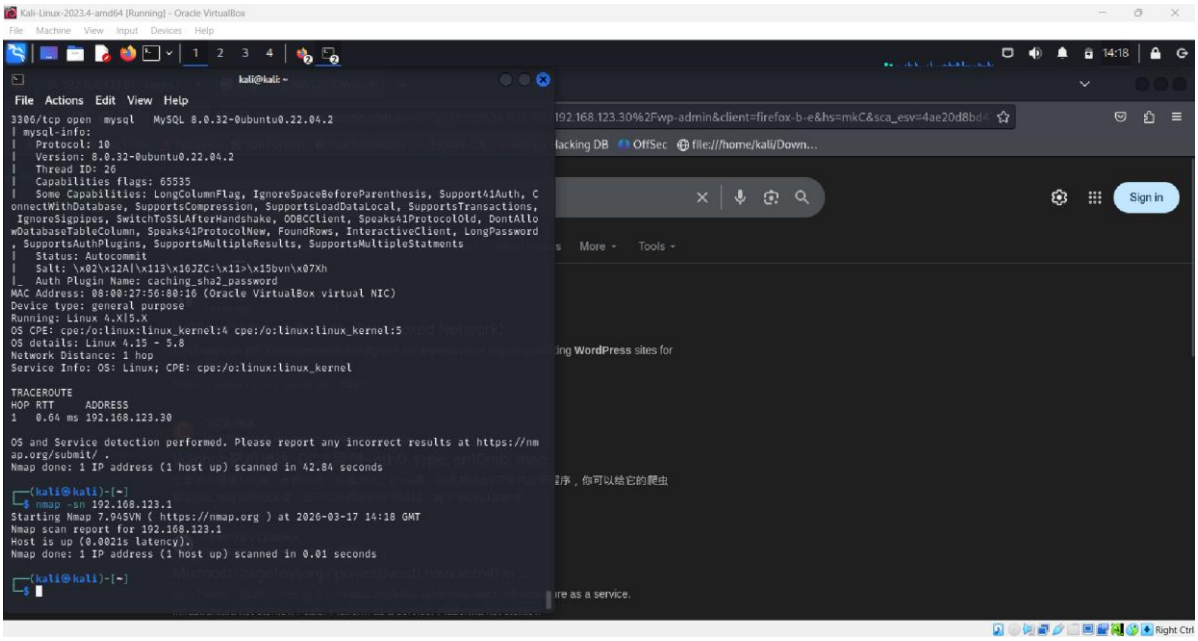

Figure 17. Service detection showed SSH, HTTP and MySQL on the WordPress host.

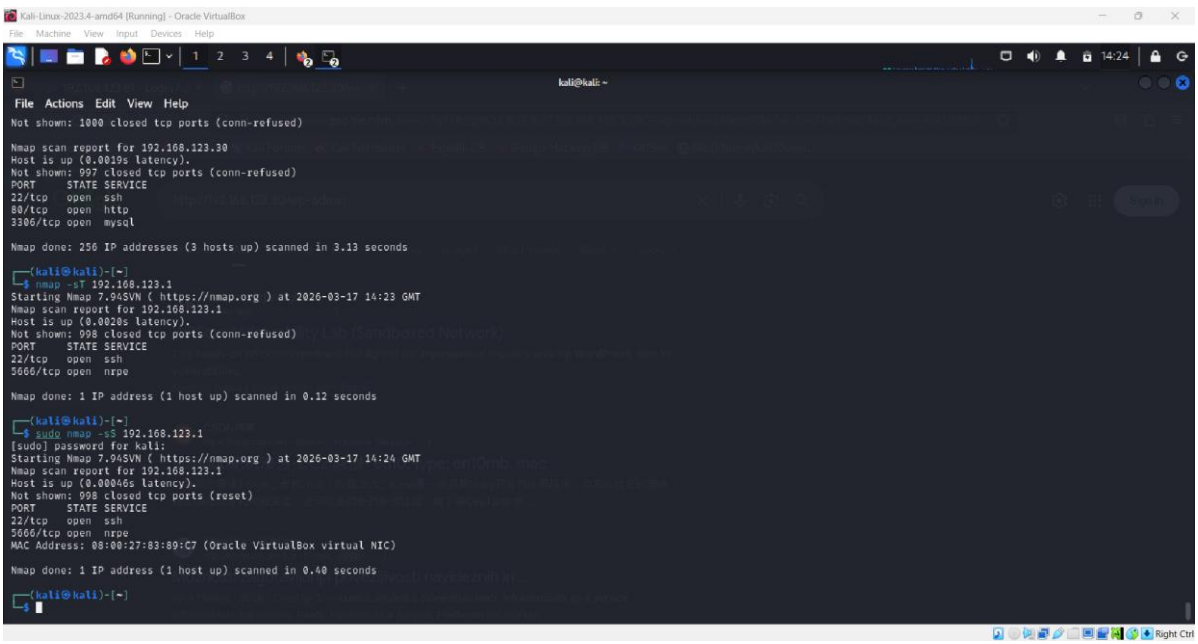

Figure 18. TCP connect and SYN scans on `192.168.123.1` both revealed SSH and NRPE, with SYN scan requiring elevated privileges.

Target	Observed services	Interpretation	Risk note
192.168.123.1	22/tcp ssh , 5666/tcp nrpe	Remote administration and monitoring services were exposed.	NRPE should only be reachable by trusted management hosts.
192.168.123.30	22/tcp ssh , 80/tcp http , 3306/tcp mysql	The host provided web, database and administration services.	Exposed database services increase the attack surface.
192.168.123.0/24	Three live hosts discovered	Basic host discovery successfully mapped	Reconnaissance is fast and valuable to

		the active lab.	attackers.

4.3 SSH evidence and findings

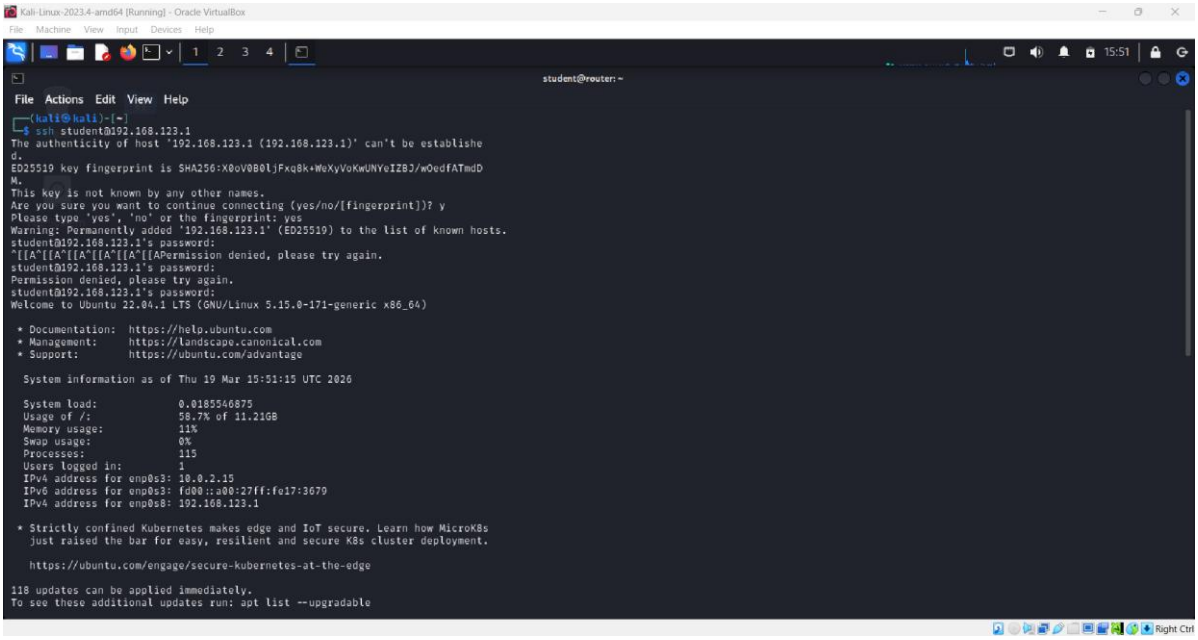

Figure 19. Initial password-based SSH login to `student@192.168.123.1` after host key verification.

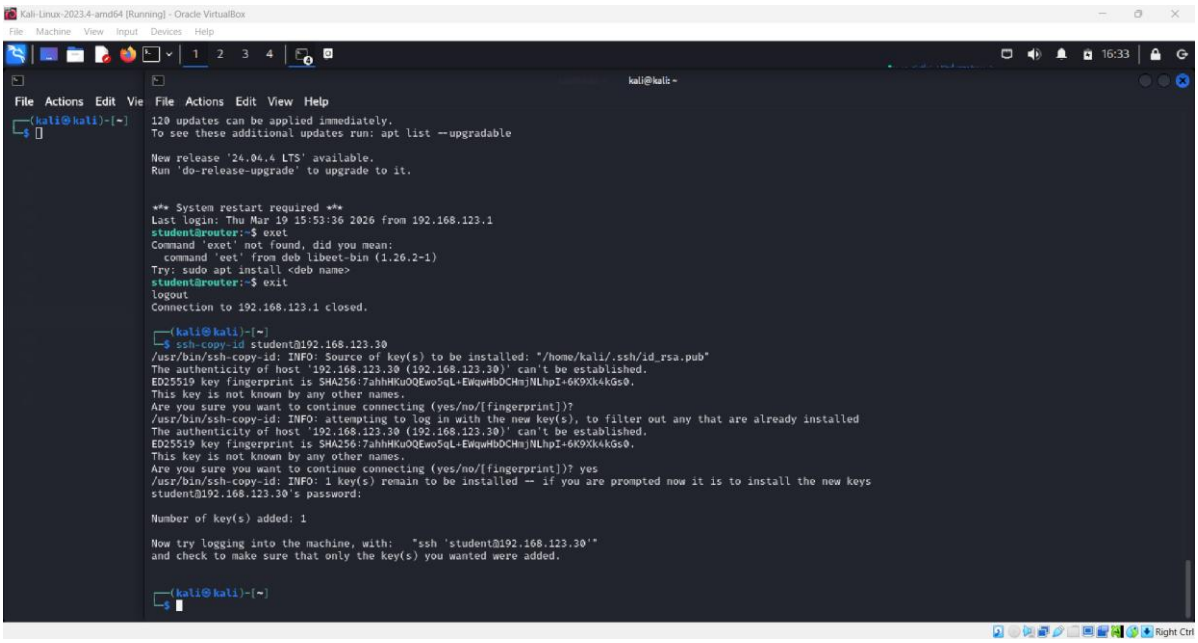

Figure 20. `ssh-copy-id` added a public key to `192.168.123.30` to support key-based authentication.

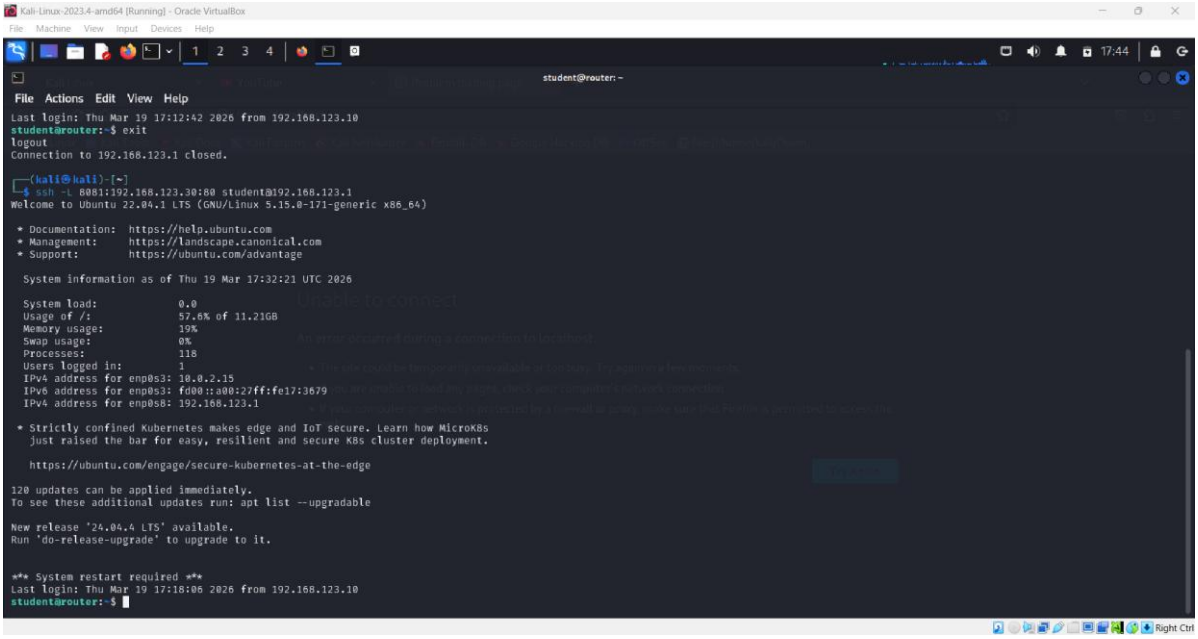

Figure 21. Local port forwarding using `ssh -L 8081:192.168.123.30:80 student@192.168.123.1`.

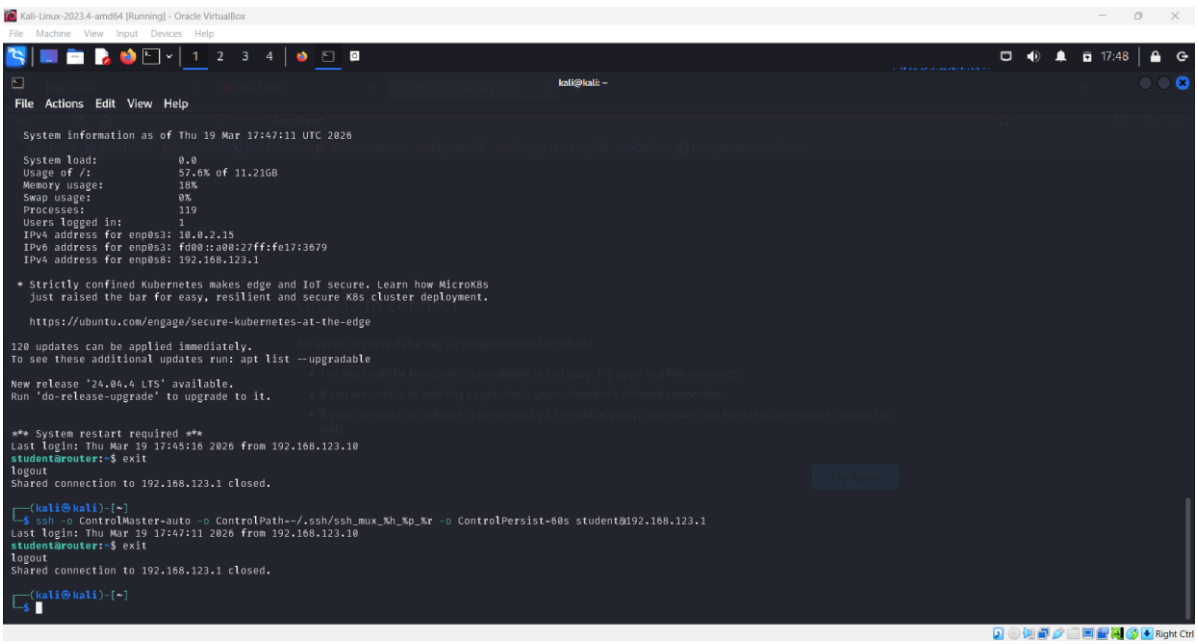

Figure 22. Secure file transfer using `scp` to move `testfile.txt` to the remote host.

The combination of Nmap and SSH made the security lesson especially clear. Nmap showed what was reachable, while SSH provided a secure way to interact with those systems once the service had been identified. The WordPress host exposing MySQL alongside HTTP and SSH would be a concern in a production network unless it was properly segmented.

From a confidentiality, integrity and availability perspective, SSH contributed directly to secure operations. Encryption protected confidentiality, host key verification supported integrity by helping prevent man-in-the-middle attacks, and tunnelling plus secure file transfer supported availability of administrative tasks without needing to expose more services than necessary.

4.4 Reflection

The most important lesson from this lab was that security tools work best in sequence. Reconnaissance identifies the surface area, and secure administration controls how that surface is managed. If I were improving this environment, I would restrict MySQL and NRPE to trusted systems only, prefer key-based authentication over passwords wherever possible and hide management workflows behind tunnels or firewall policy rather than exposing them broadly.

5. Week 09 - Vulnerability Scanning and Mitigation Lab (Nessus)

5.1 Aim

The final lab focused on formal vulnerability scanning with Nessus. The task involved installing or configuring the scanner, accessing the web interface, creating scans, reviewing findings and exporting reports. This lab moved beyond ad hoc testing into a more structured vulnerability management workflow.

5.2 Evidence

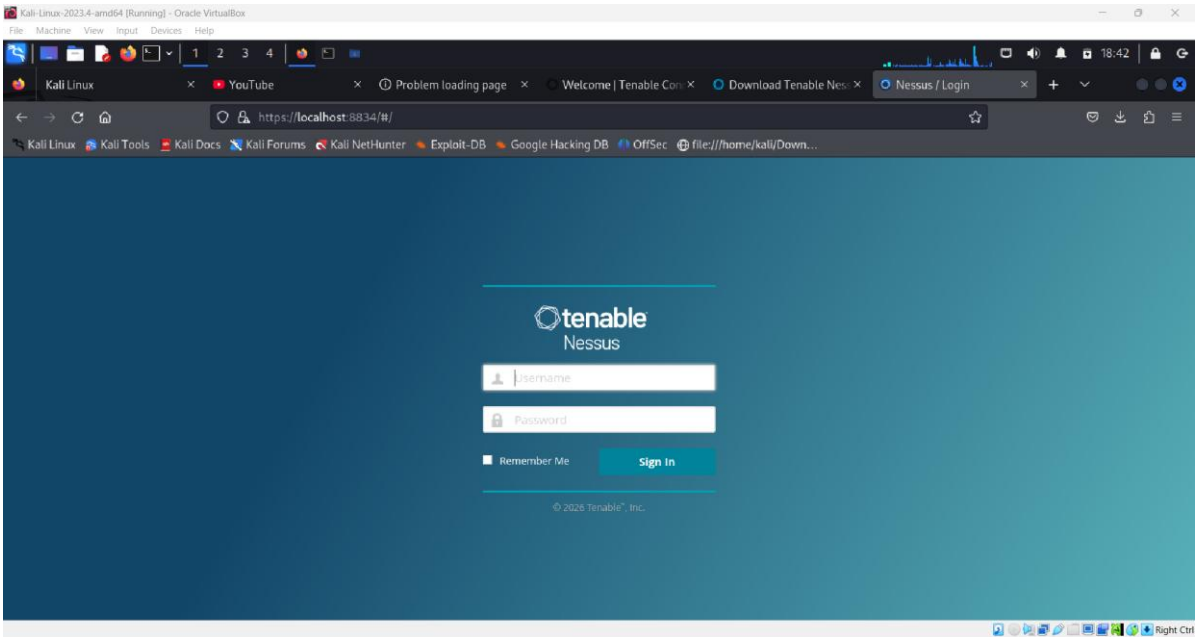

Figure 23. Nessus web interface available at `https://localhost:8834`.

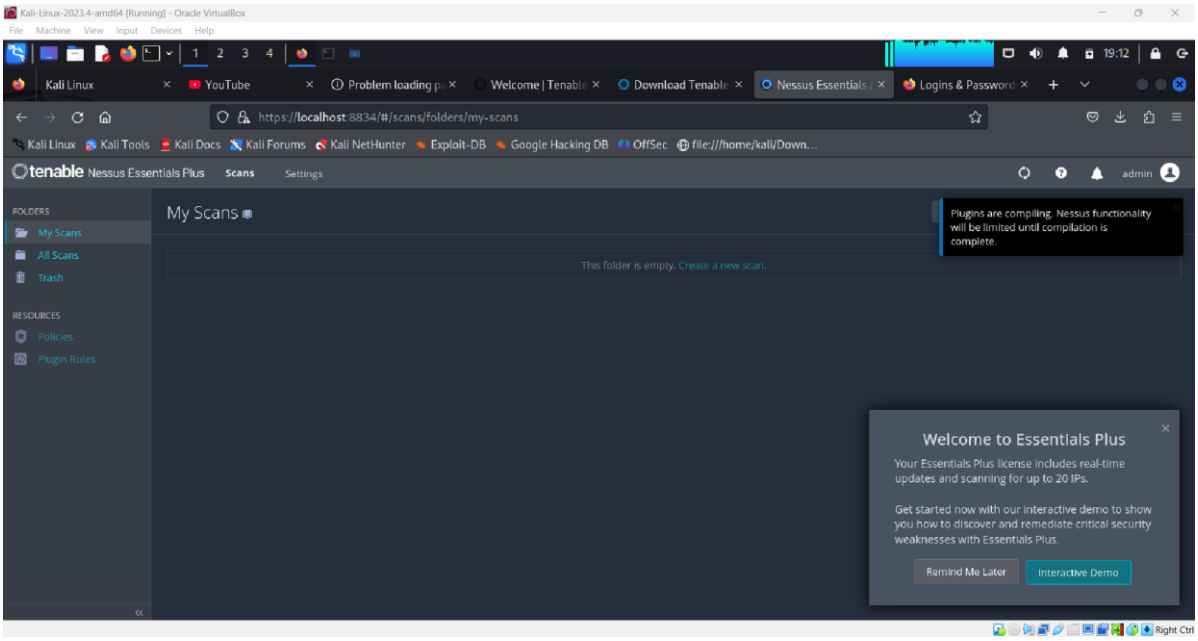

Figure 24. Nessus was ready for use after setup and plugin compilation.

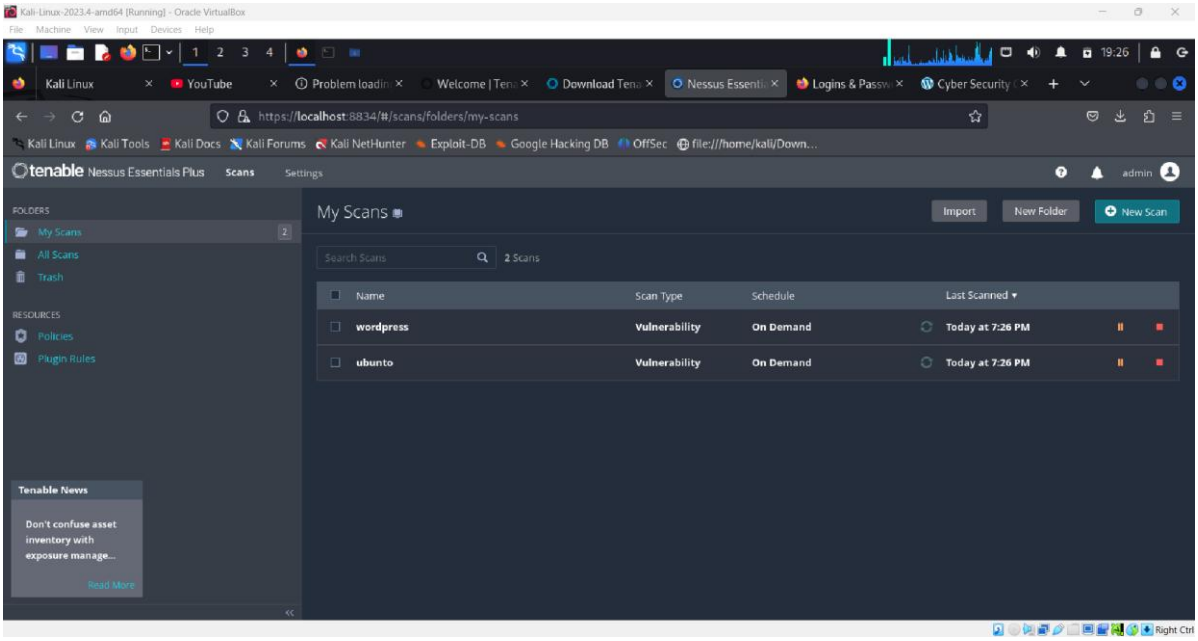

Figure 25. Two scan jobs were created: `wordpress` and `ubuntu`.

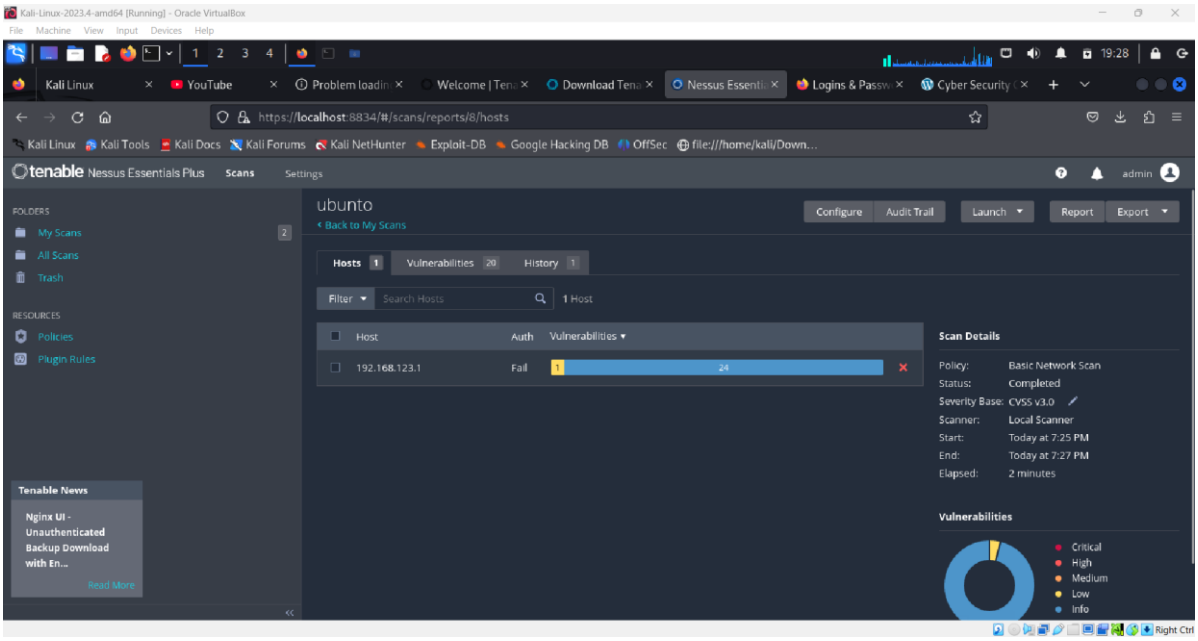

Figure 26. Ubuntu scan results inside Nessus.

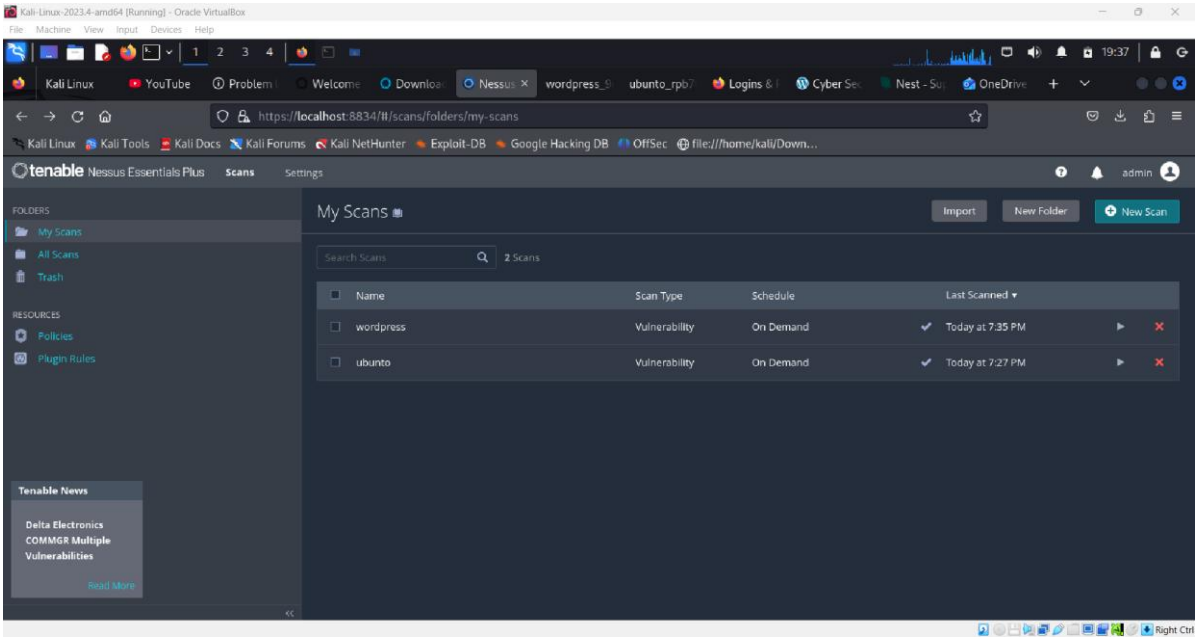

Figure 27. Both scans completed successfully.

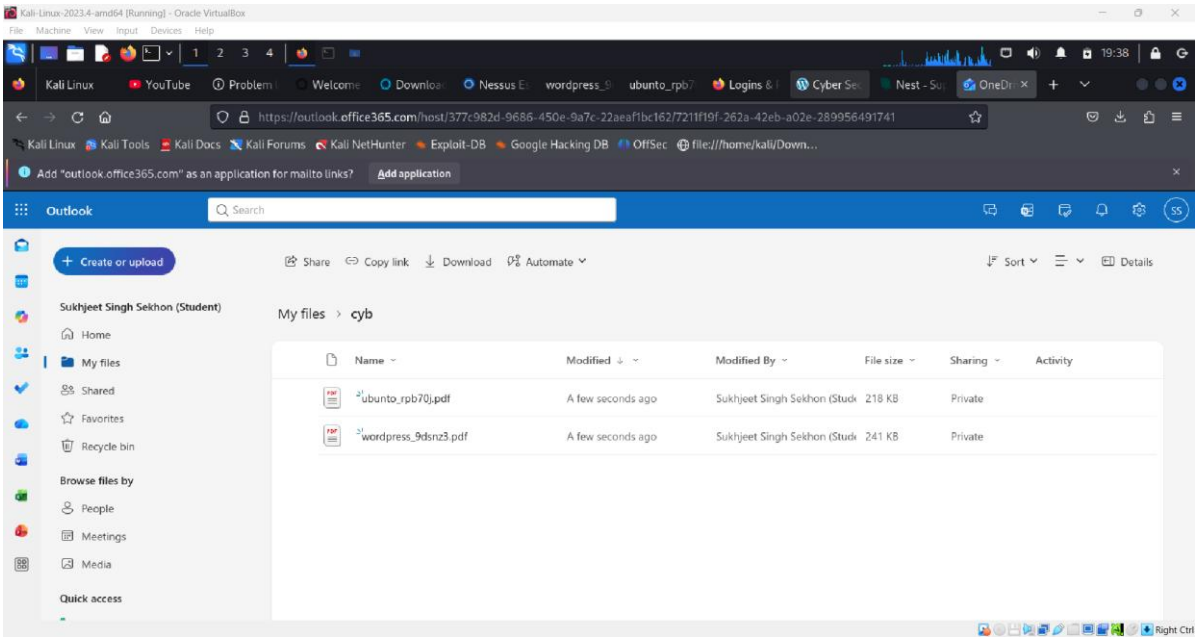

Figure 28. Exported PDF reports for both assets were saved as evidence.

5.3 Scan summary

Target	Evidence source	Severity summary	Most important finding
Ubuntu host 192.168.123.1	ubunto_rpb70j.pdf	0 Critical, 0 High, 0 Medium, 1 Low, 24 Info	ICMP Timestamp Request Remote Date Disclosure
WordPress host 192.168.123.30	wordpress_9dsnz3.pdf	0 Critical, 0 High, 1 Medium, 1 Low, 32 Info	SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)

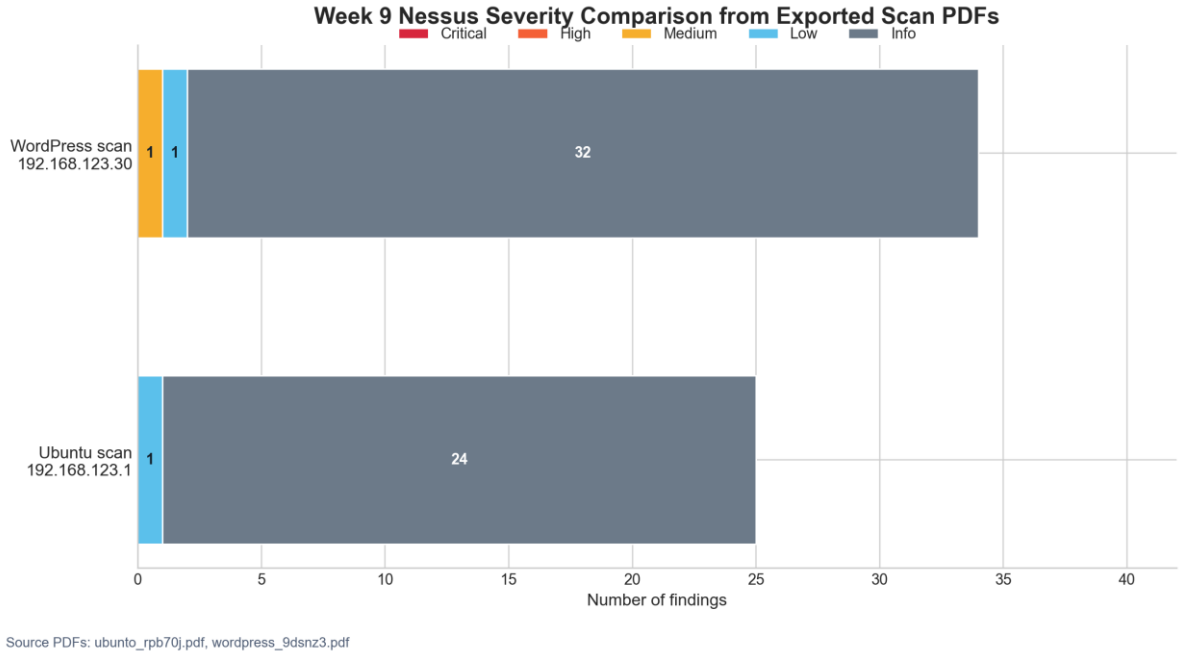

Figure 29. Severity comparison graph generated from the exported Nessus scan PDFs for the Ubuntu and WordPress hosts.

The graph above provides a clearer comparison of the two exported scans. It shows that both hosts were dominated by informational findings, but only the WordPress host contained a medium-severity issue. This visual comparison strengthens the Week 09 analysis because it makes the difference in risk profile immediately visible rather than leaving it only in table form.

5.4 Analysis

The Ubuntu scan was relatively clean in severity terms. It produced mainly informational findings, with the only low-severity issue being ICMP timestamp disclosure. That means the host did not show obvious severe remotely visible weaknesses in the captured assessment, although the informational findings still revealed useful platform detail to an attacker.

The WordPress host produced the more important result. Nessus reported `SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)` as a medium-severity issue affecting the SSH service. This matters because it can weaken integrity protections during a man-in-the-middle scenario when certain algorithms are enabled. The host also returned the same ICMP timestamp disclosure seen on Ubuntu.

Finding	Affected host	Why it matters	Recommended mitigation
SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)	192.168.123.30	The SSH service may be vulnerable to a downgrade of integrity protections in a man-in-the-middle scenario.	Apply OpenSSH vendor updates with strict key exchange countermeasures or disable affected algorithms where appropriate.
ICMP Timestamp Request Remote Date Disclosure	192.168.123.1 and 192.168.123.30	Accurate time information is revealed to unauthenticated remote probes.	Filter ICMP timestamp request and reply types if not operationally required.
Large number of informational findings	Both hosts	Informational results do not always indicate exploitability, but they show how much platform detail is visible.	Reduce unnecessary exposure, keep systems patched and use credentialed scans for higher confidence.

One particularly useful detail from the screenshots was that the Ubuntu scan showed authentication as failed, which means the assessment was effectively remote and unauthenticated. That is still useful, but it also means a follow-up credentialed scan would likely produce deeper and more accurate results.

5.5 Reflection

This lab showed how vulnerability management differs from one-off testing. Running a scan is only the first step. The more valuable part is interpreting the output, prioritising the findings and converting them into mitigation actions. Nessus was especially useful because it turned the technical observations into a reportable format, which is important in professional security work.

6. Overall Reflection and Conclusion

Across the four labs, I used scanning, exploitation and secure administration techniques to examine security from different angles. Week 05 showed how a WordPress site can leak operational detail through enumeration. Week 07 demonstrated how application flaws can be abused directly. Week 08 connected network reconnaissance with secure remote access, and Week 09 formalised the process through structured vulnerability scanning and reporting.

The strongest overall lesson was that security work requires both technical skill and critical judgment. Tools can identify possible weaknesses, but the analyst still has to decide what those results mean, how severe they really are and what the most suitable mitigation should be. This portfolio helped develop that combination of practical and analytical thinking.

7. AI Use Statement

I used ChatGPT as an editorial support tool to help organise my existing lab evidence into a coherent report, improve grammar and structure, and turn my screenshots and exported results into clearer written explanations. The screenshots, commands, scan outputs and Nessus reports themselves were based on my own lab work. AI was not used to fabricate evidence or invent results that were not present in the collected material.

8. References

1. University of Roehampton, *Assessment Brief CMP-X305 Portfolio*, local PDF provided with the coursework.
2. University lab sheet, *Portfolio Lab on WPScan for Penetration Testing of a WordPress Site*, local PDF provided in Week 05.
3. WPScan Team, "WPScan WordPress Security Scanner." Available: https://wpscan.com/
4. University lab sheet, *BSC Juice-Shop Lab*, local PDF provided in Week 07.
5. OWASP Foundation, "OWASP Juice Shop." Available: https://owasp.org/www-project-juice-shop/
6. OWASP Juice Shop companion guide, "Pwning OWASP Juice Shop." Available: https://pwning.owasp-juice.shop/
7. University lab sheet, *An Introduction to Nmap*, local PDF provided in Week 08.
8. Nmap Project, "Nmap Reference Guide." Available: https://nmap.org/book/man.html
9. University lab sheet, *Introduction to SSH (Secure Shell)*, local PDF provided in Week 08.
10. OpenSSH, "OpenSSH Manual Pages." Available: https://www.openssh.com/manual.html
11. University lab sheet, *Vulnerability Scanning Using Nessus Lab*, local PDF provided in Week 09.
12. Tenable, "Nessus." Available: https://www.tenable.com/products/nessus
13. Tenable Documentation, "Nessus Documentation." Available: https://docs.tenable.com/nessus/
14. Exported evidence reports, *ubunto_rpb70j.pdf* and *wordpress_9dsnz3.pdf*, generated by Nessus on 19 March 2026.
15. OpenAI, "ChatGPT." Available: https://chatgpt.com/